Skill 2: Enabling MFA on the AWS Root User

Course: Cloud Infrastructure and Services (25CS2206E)

Trimester: 2026-2027 Even Trimester (T5)

Name: Talluri Himabindu Sree

Roll No: 2520030484

Aim

To enable multi-factor authentication (MFA) on the AWS root user using a virtual MFA device, check that the sign-in now asks for an MFA code, and prepare a short note comparing virtual MFA devices, hardware MFA devices and FIDO security keys.

Prerequisites

- An active AWS account
- Root user email address and password
- Access to the registered email in case AWS asks for verification
- A smartphone with an authenticator app (Google Authenticator or Microsoft Authenticator)
- Internet connection

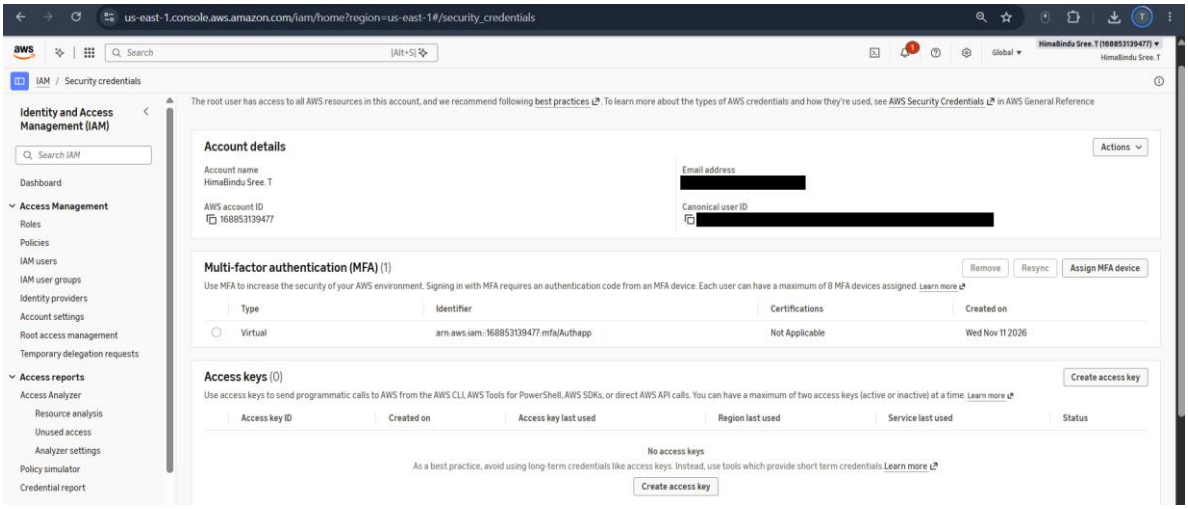
Procedure

Part A: Enabling MFA on the root user

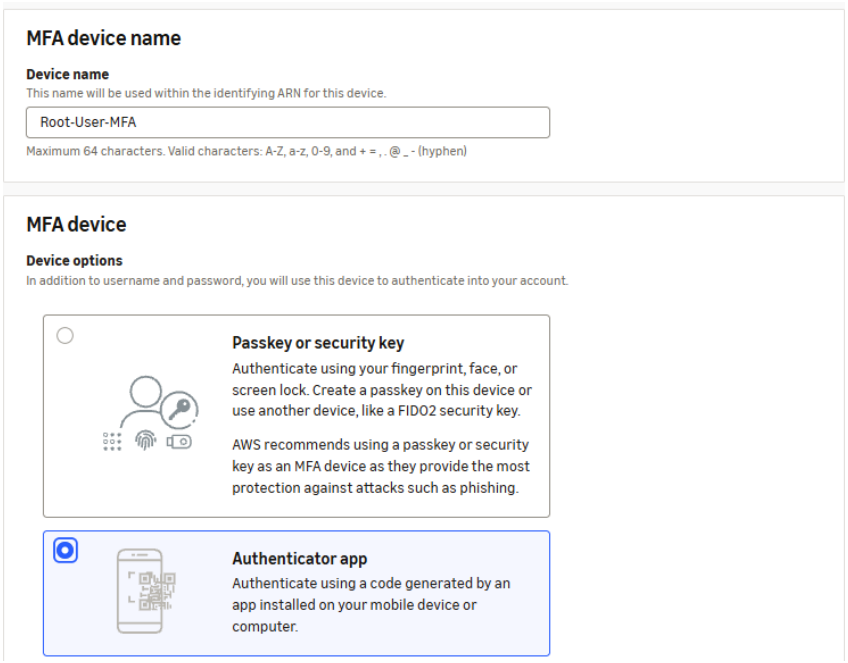
1. Opened the AWS Management Console and signed in as the root user with the account email and password.
2. Completed any verification step AWS asked for.
3. Clicked my account name in the top-right corner and selected Security credentials.
4. Scrolled to the Multi-factor authentication (MFA) section and clicked Assign MFA device.
5. Entered the device name Authapp.
6. Selected Authenticator app (Virtual MFA device) as the device type and clicked Next.
7. AWS showed a QR code. On my phone I opened the authenticator app, chose to add a new account and scanned the QR code.
8. The app started producing a six-digit time-based one-time password (TOTP).
9. Typed the first code into the MFA code 1 field, waited for the app to refresh, then typed the next code into MFA code 2.
10. Clicked Add MFA.
11. Checked that the virtual MFA device now appears under the root user's MFA section.

Note: The device Authapp was registered earlier. Screenshots 2, 3, 4 and 8 were taken on a repeat walkthrough of the Assign MFA device page, since the original setup was done earlier. I did not use it to replace my registered device, so the name shown there can differ.

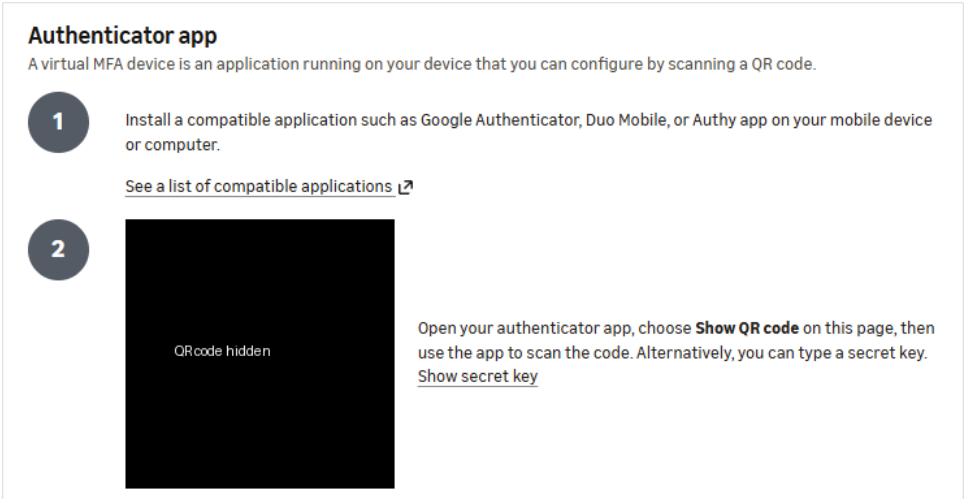
Note: The QR code and the secret key are what generate the codes, so I kept them out of my screenshots (or covered them) to avoid exposing my root account.



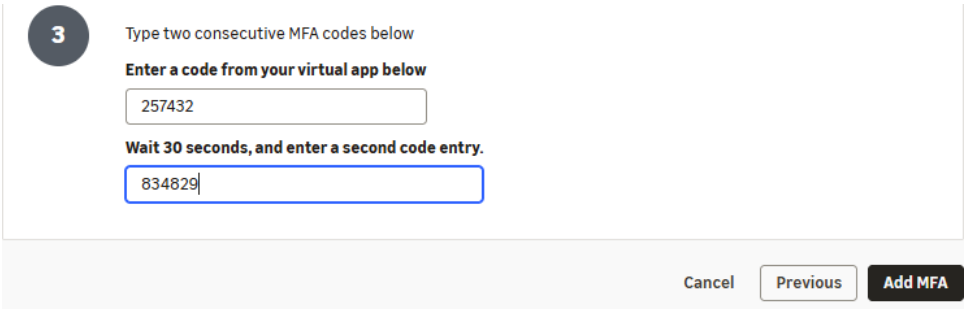
Screenshot 1: Security credentials page with the MFA section



Screenshot 2: Assign MFA device page with the device name and Authenticator app selected



Screenshot 3: QR code step (QR code hidden)



Screenshot 4: Two consecutive MFA codes entered, before clicking Add MFA

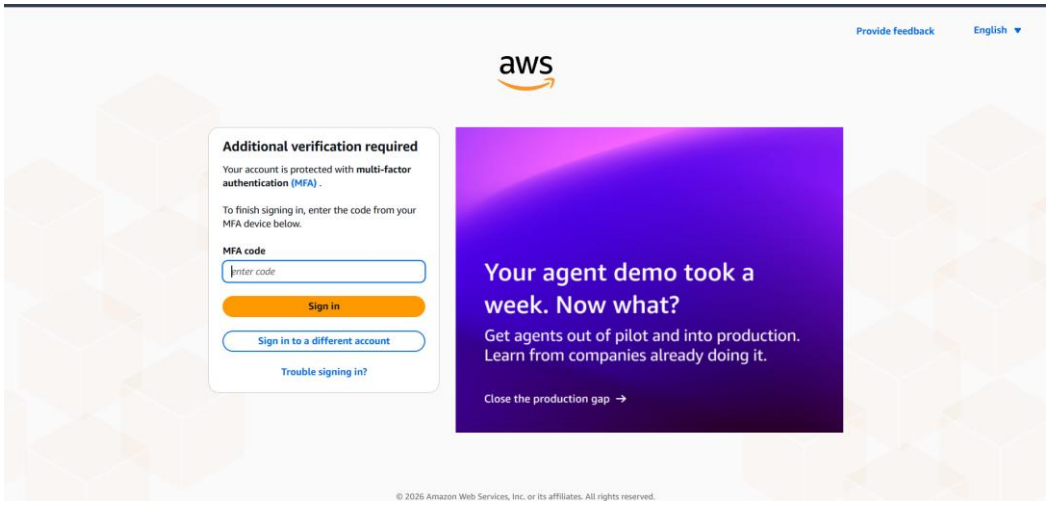


Screenshot 5: Virtual MFA device listed under the root user's MFA section

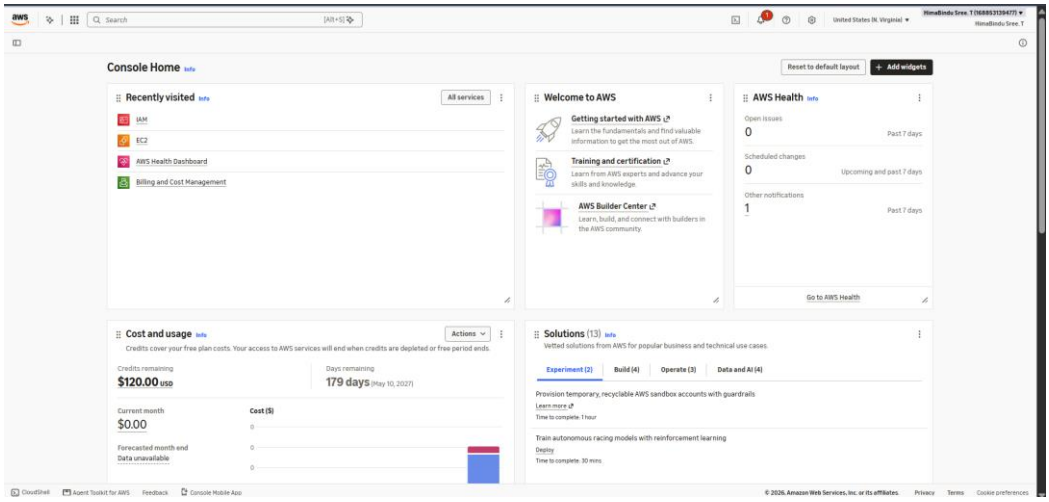
Part B: Verifying MFA sign-in

1. Signed out of the AWS Management Console.
2. Opened the sign-in page and selected Root user.
3. Entered the root email address and password.
4. AWS now asked for an MFA code.
5. Opened the authenticator app and entered the six-digit code currently shown.
6. Clicked Submit and reached the console successfully.

The code changes every 30 seconds or so, so I entered the current one before it expired.



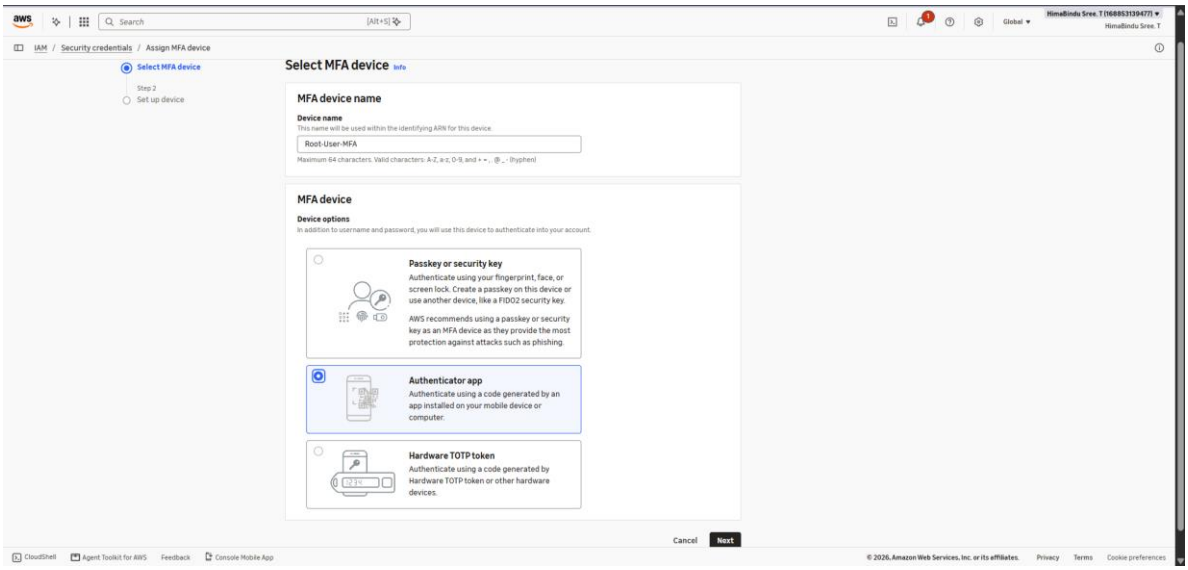
Screenshot 6: MFA code prompt on the root sign-in page



Screenshot 7: AWS Management Console after a successful sign-in

Part C: Note on MFA device types

AWS lets the root user choose between three kinds of MFA. This is how I understood each one.



Screenshot 8: Select MFA device page showing the available device types

Point	Virtual MFA	Hardware MFA (TOTP token)	FIDO security key
What it is	An authenticator app on a phone or computer	A small physical token with its own display	A physical key (e.g. YubiKey) that you plug in or tap
How it works	App shows a six-digit time-based code that I type in	Token shows a six-digit time-based code that I type in	Key proves my identity with public-key cryptography, usually with a touch or fingerprint
Examples	Google Authenticator, Microsoft Authenticator	AWS-supported hardware TOTP tokens	YubiKey and other AWS-supported FIDO keys

Point	Virtual MFA	Hardware MFA (TOTP token)	FIDO security key
Cost	Free	Has to be bought	Has to be bought (usually costs more)
Convenience	Very easy, phone is always with me	Extra thing to carry, battery runs out	Extra thing to carry, needs a USB, NFC or Bluetooth connection
Phishing resistance	Low, a fake site can collect the typed code	Low, same as virtual	High, key only works with the real site
Main risk	Losing or resetting the phone	Losing the token or a dead battery	Losing the key

My takeaway

- Virtual MFA is the easiest to set up and is fine for learning and basic accounts.
- Hardware tokens do not depend on a phone, but they still rely on typed codes.
- FIDO security keys are the strongest option because they resist phishing.
- Whichever type is used, registering a second MFA device as a backup is a good idea so I am not locked out if one is lost.

Outcomes Achieved

- Enabled a virtual MFA device on the AWS root user
- Registered it using the QR code and two consecutive codes
- Confirmed the root sign-in now needs an MFA code
- Compared virtual, hardware and FIDO MFA options

Result

MFA was enabled on the AWS root user with an authenticator app, the sign-in was tested with the MFA code, and a comparison of virtual MFA, hardware MFA and FIDO security keys was prepared.